



ZAP Scanning Report

Site: <http://localhost:3000>

Generated on Thu, 6 Aug 2026 02:24:53

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	4
Low	9
Informational	9
False Positives:	0

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	1
Low	Warning		ZAP warnings logged - see the zap.log file for details	26
Info	Informational	http://localhost:3000	Percentage of responses with status code 1xx	1 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 2xx	98 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 4xx	1 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/javascript	63 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/json	22 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type font/woff2	1 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type image/svg+xml	2 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/css	2 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/html	3 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/plain	1 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/x-component	1 %
Info	Informational	http://localhost:3000	Percentage of endpoints with method GET	96 %
Info	Informational	http://localhost:3000	Percentage of endpoints with method POST	3 %
Info	Informational	http://localhost:3000	Count of total endpoints	76
Info	Informational	http://localhost:3000	Percentage of slow responses	26 %

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
CSP: Wildcard Directive	Medium	2
CSP: script-src unsafe-eval	Medium	3
CSP: script-src unsafe-inline	Medium	3
CSP: style-src unsafe-inline	Medium	3
Cross-Origin-Embedder-Policy Header Missing or Invalid	Low	1
Cross-Origin-Opener-Policy Header Missing or Invalid	Low	1
Cross-Origin-Resource-Policy Header Missing or Invalid	Low	Systemic
Dangerous JS Functions	Low	1
Full Path Disclosure	Low	2
Permissions Policy Header Not Set	Low	Systemic
Private IP Disclosure	Low	4
Timestamp Disclosure - Unix	Low	2
X-Content-Type-Options Header Missing	Low	Systemic
Base64 Disclosure	Informational	11
Information Disclosure - Suspicious Comments	Informational	36
Modern Web Application	Informational	4
Non-Storable Content	Informational	Systemic
Sec-Fetch-Dest Header is Missing	Informational	3
Sec-Fetch-Mode Header is Missing	Informational	3
Sec-Fetch-Site Header is Missing	Informational	3
Sec-Fetch-User Header is Missing	Informational	3
Storable but Non-Cacheable Content	Informational	2

Alert Detail

Medium	CSP: Wildcard Directive
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:3000
Node Name	http://localhost:3000
Method	GET

Parameter	content-security-policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob;; frame-src 'self' blob;; font-src 'self'; connect-src 'self' ws: wss;; frame-ancestors 'none'; base-uri 'self'; form-action 'self'
Other Info	The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: connect-src
URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Method	GET
Parameter	content-security-policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob;; frame-src 'self' blob;; font-src 'self'; connect-src 'self' ws: wss;; frame-ancestors 'none'; base-uri 'self'; form-action 'self'
Other Info	The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: connect-src
Instances	2
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	CSP: script-src unsafe-eval
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:3000
Node Name	http://localhost:3000
Method	GET
Parameter	content-security-policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob;; frame-src 'self' blob;; font-src 'self'; connect-src 'self' ws: wss;; frame-ancestors

	'none'; base-uri 'self'; form-action 'self'
Other Info	script-src includes unsafe-eval.
URL	http://localhost:3000/robots.txt
Node Name	http://localhost:3000/robots.txt
Method	GET
Parameter	content-security-policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; frame-src 'self' blob:; font-src 'self'; connect-src 'self' ws: wss:; frame-ancestors 'none'; base-uri 'self'; form-action 'self'
Other Info	script-src includes unsafe-eval.
URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Method	GET
Parameter	content-security-policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; frame-src 'self' blob:; font-src 'self'; connect-src 'self' ws: wss:; frame-ancestors 'none'; base-uri 'self'; form-action 'self'
Other Info	script-src includes unsafe-eval.
Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	CSP: script-src unsafe-inline
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:3000
Node Name	http://localhost:3000
Method	GET
Parameter	content-security-policy

Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; frame-src 'self' blob:; font-src 'self'; connect-src 'self' ws: wss:; frame-ancestors 'none'; base-uri 'self'; form-action 'self'
Other Info	script-src includes unsafe-inline.
URL	http://localhost:3000/robots.txt
Node Name	http://localhost:3000/robots.txt
Method	GET
Parameter	content-security-policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; frame-src 'self' blob:; font-src 'self'; connect-src 'self' ws: wss:; frame-ancestors 'none'; base-uri 'self'; form-action 'self'
Other Info	script-src includes unsafe-inline.
URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Method	GET
Parameter	content-security-policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; frame-src 'self' blob:; font-src 'self'; connect-src 'self' ws: wss:; frame-ancestors 'none'; base-uri 'self'; form-action 'self'
Other Info	script-src includes unsafe-inline.
Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	CSP: style-src unsafe-inline
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:3000
Node Name	http://localhost:3000

Method	GET
Parameter	content-security-policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob;; frame-src 'self' blob;; font-src 'self'; connect-src 'self' ws: wss;; frame-ancestors 'none'; base-uri 'self'; form-action 'self'
Other Info	style-src includes unsafe-inline.
URL	http://localhost:3000/robots.txt
Node Name	http://localhost:3000/robots.txt
Method	GET
Parameter	content-security-policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob;; frame-src 'self' blob;; font-src 'self'; connect-src 'self' ws: wss;; frame-ancestors 'none'; base-uri 'self'; form-action 'self'
Other Info	style-src includes unsafe-inline.
URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Method	GET
Parameter	content-security-policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob;; frame-src 'self' blob;; font-src 'self'; connect-src 'self' ws: wss;; frame-ancestors 'none'; base-uri 'self'; form-action 'self'
Other Info	style-src includes unsafe-inline.
Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Low	Cross-Origin-Embedder-Policy Header Missing or Invalid
Description	Cross-Origin-Embedder-Policy header is a response header that prevents a document from loading any cross-origin resources that don't explicitly grant the document permission (using CORP or CORS).
URL	http://localhost:3000
Node Name	http://localhost:3000

Method	GET
Parameter	Cross-Origin-Embedder-Policy
Attack	
Evidence	
Other Info	
Instances	1
Solution	Ensure that the application/web server sets the Cross-Origin-Embedder-Policy header appropriately, and that it sets the Cross-Origin-Embedder-Policy header to 'require-corp' for documents. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Embedder-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-embedder-policy).
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy
CWE Id	693
WASC Id	14
Plugin Id	90004

Low	Cross-Origin-Opener-Policy Header Missing or Invalid
Description	Cross-Origin-Opener-Policy header is a response header that allows a site to control if others included documents share the same browsing context. Sharing the same browsing context with untrusted documents might lead to data leak.
URL	http://localhost:3000
Node Name	http://localhost:3000
Method	GET
Parameter	Cross-Origin-Opener-Policy
Attack	
Evidence	same-origin-allow-popups
Other Info	
Instances	1
Solution	Ensure that the application/web server sets the Cross-Origin-Opener-Policy header appropriately, and that it sets the Cross-Origin-Opener-Policy header to 'same-origin' for documents. 'same-origin-allow-popups' is considered as less secured and should be avoided. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Opener-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-opener-policy).
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Opener-Policy
CWE Id	693
WASC Id	14
Plugin Id	90004

Low	Cross-Origin-Resource-Policy Header Missing or Invalid
------------	---

Description	Cross-Origin-Resource-Policy header is an opt-in header designed to counter side-channels attacks like Spectre. Resource should be specifically set as shareable amongst different origins.
URL	http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._js
Node Name	http://localhost:3000/_next/static/chunks/[turbopack]_browser_dev_hmr-client_hmr-client_ts_57d40746._js
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/_next/static/chunks/_a0ff3932._js
Node Name	http://localhost:3000/_next/static/chunks/_a0ff3932._js
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/_next/static/chunks/_e084681a._css
Node Name	http://localhost:3000/_next/static/chunks/_e084681a._css
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/icon.svg
Node Name	http://localhost:3000/icon.svg
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/nycu-favicon.svg
Node Name	http://localhost:3000/nycu-favicon.svg
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	
Evidence	

Other Info	
Instances	Systemic
Solution	Ensure that the application/web server sets the Cross-Origin-Resource-Policy header appropriately, and that it sets the Cross-Origin-Resource-Policy header to 'same-origin' for all web pages. 'same-site' is considered as less secured and should be avoided. If resources must be shared, set the header to 'cross-origin'. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Resource-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-resource-policy).
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy
CWE Id	693
WASC Id	14
Plugin Id	90004

Low	Dangerous JS Functions
Description	A dangerous JS function seems to be in use that would leave the site vulnerable.
URL	http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js
Node Name	http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js
Method	GET
Parameter	
Attack	
Evidence	eval(
Other Info	
Instances	1
Solution	See the references for security advice on the use of these functions.
Reference	https://v17.angular.io/guide/security
CWE Id	749
WASC Id	
Plugin Id	10110

Low	Full Path Disclosure
Description	The full path of files which might be sensitive has been exposed to the client.
URL	http://localhost:3000/robots.txt
Node Name	http://localhost:3000/robots.txt
Method	GET
Parameter	
Attack	
Evidence	/lib/
Other Info	

URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	/lib/
Other Info	
Instances	2
Solution	Disable directory browsing in your web server. Refer to the web server documentation.
Reference	https://owasp.org/www-community/attacks/Full_Path_Disclosure
CWE Id	209
WASC Id	13
Plugin Id	110009

Low	Permissions Policy Header Not Set
Description	Permissions Policy Header is an added layer of security that helps to restrict from unauthorized access or usage of browser/client features by web resources. This policy ensures the user privacy by limiting or specifying the features of the browsers can be used by the web resources. Permissions Policy provides a set of standard HTTP headers that allow website owners to limit which features of browsers can be used by the page such as camera, microphone, location, full screen etc.
URL	http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._.js
Node Name	http://localhost:3000/_next/static/chunks/[turbopack]_browser_dev_hmr-client_hmr-client_ts_57d40746._.js
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/_next/static/chunks/_8bb8c147._.js
Node Name	http://localhost:3000/_next/static/chunks/_8bb8c147._.js
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/_next/static/chunks/_a0ff3932._.js
Node Name	http://localhost:3000/_next/static/chunks/_a0ff3932._.js
Method	GET
Parameter	

Attack	
Evidence	
Other Info	
URL	http://localhost:3000/_next/static/chunks/app_layout_tsx_0a548d63._.js
Node Name	http://localhost:3000/_next/static/chunks/app_layout_tsx_0a548d63._.js
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/_next/static/chunks/node_modules_%40swc_helpers_cjs_b3dc30d6._.js
Node Name	http://localhost:3000/_next/static/chunks/node_modules_@swc_helpers_cjs_b3dc30d6._.js
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Permissions-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Permissions-Policy https://developer.chrome.com/blog/feature-policy/ https://scotthelme.co.uk/a-new-security-header-feature-policy/ https://w3c.github.io/webappsec-feature-policy/ https://www.smashingmagazine.com/2018/12/feature-policy/
CWE Id	693
WASC Id	15
Plugin Id	10063

Low	Private IP Disclosure
Description	A private IP (such as 10.x.x.x, 172.x.x.x, 192.168.x.x) or an Amazon EC2 private hostname (for example, ip-10-0-56-78) has been found in the HTTP response body. This information might be helpful for further attacks targeting internal systems.
URL	http://localhost:3000
Node Name	http://localhost:3000
Method	GET
Parameter	
Attack	
Evidence	172.30.0.1
Other Info	172.30.0.1
URL	http://localhost:3000/

Node Name	http://localhost:3000/
Method	GET
Parameter	
Attack	
Evidence	172.30.0.1
Other Info	172.30.0.1
URL	http://localhost:3000/robots.txt
Node Name	http://localhost:3000/robots.txt
Method	GET
Parameter	
Attack	
Evidence	172.30.0.1
Other Info	172.30.0.1
URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	172.30.0.1
Other Info	172.30.0.1
Instances	4
Solution	Remove the private IP address from the HTTP response body. For comments, use JSP/ASP/PHP comment instead of HTML/JavaScript comment which can be seen by client browsers.
Reference	https://datatracker.ietf.org/doc/html/rfc1918
CWE Id	497
WASC Id	13
Plugin Id	2

Low	Timestamp Disclosure - Unix
Description	A timestamp was disclosed by the application/web server. - Unix
URL	http://localhost:3000/_next/static/chunks/node_modules_84eac506._.js
Node Name	http://localhost:3000/_next/static/chunks/node_modules_84eac506._.js
Method	GET
Parameter	
Attack	
Evidence	1866099640
Other Info	1866099640, which evaluates to: 2029-02-18 09:00:40.
URL	http://localhost:3000/_next/static/chunks/node_modules_%40floating-ui_1b6e7b6d._.js

Node Name	http://localhost:3000/_next/static/chunks/node_modules_@floating-ui_1b6e7b6d._.js
Method	GET
Parameter	
Attack	
Evidence	1719601643
Other Info	1719601643, which evaluates to: 2024-06-28 19:07:23.
Instances	2
Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.
Reference	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497
WASC Id	13
Plugin Id	10096

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._.js
Node Name	http://localhost:3000/_next/static/chunks/[turbopack]_browser_dev_hmr-client_hmr-client_ts_57d40746._.js
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:3000/_next/static/chunks/_e084681a._.css
Node Name	http://localhost:3000/_next/static/chunks/_e084681a._.css
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:3000/_next/static/chunks/node_modules_%40swc_helpers_cjs_b3dc30d6._.js

Node Name	http://localhost:3000/_next/static/chunks/node_modules_@swc_helpers_cjs_b3dc30d6._.js
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:3000/icon.svg
Node Name	http://localhost:3000/icon.svg
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:3000/nycu-favicon.svg
Node Name	http://localhost:3000/nycu-favicon.svg
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	Systemic
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Attack	
Evidence	export __default__ as __Building2
Other Info	{SUBh0000u!ESC?DELD]J
URL	http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js
Node Name	http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js
Method	GET
Parameter	
Attack	
Evidence	/node_modules/zod/v3/helpers/parseUtil
Other Info	z[?v?^??w?ETB:?????????-?
URL	http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a._.js
Node Name	http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a._.js
Method	GET
Parameter	
Attack	
Evidence	com/facebook/create-react-app/blob/7b1a32be6ec9f99a6c9a3c66813f3ac09c4736b9/packages/react-dev-utils/formatWebpackMessages
Other Info	r}n\$?j閨初槽 oV?y?_?ss?w?i?=s???\$j???rPz?)l??+??VyZrC:Oz
URL	http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js
Node Name	http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js
Method	GET
Parameter	
Attack	
Evidence	com/webpack/webpack/blob/3aa6b6bc3a64/lib/hmr/HotModuleReplacement
Other Info	r????i?i?nZESC?v?窠sv???bo?f????gs?W?z?Zq韓
URL	http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js
Node Name	http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js
Method	GET
Parameter	
Attack	
Evidence	com/webpack/webpack/blob/6be4065ade1e252c1d8dcba4af0f43e32af1bdc1/lib/runtime/AsyncModuleRuntimeModule
Other Info	r????i?i? nZESC???N?i[?nvsW u????f?2\???bo??{?,?WFF?yESC??)2n
URL	http://localhost:3000/robots.txt
Node Name	http://localhost:3000/robots.txt

Parameter	
Attack	
Evidence	<code>/** * Log debug messages (developme</code>
Other Info	The following pattern was used: <code>\bDEBUG\b</code> and was detected 2 times, the first in likely comment: <code>"/**</code> <code>* Log debug messages (development only)</code> <code>*/", see evidence field for the suspicious comment/snippet.</code>
URL	http://localhost:3000/_next/static/chunks/_6592d88f._.js
Node Name	<code>http://localhost:3000/_next/static/chunks/_6592d88f._.js</code>
Method	GET
Parameter	
Attack	
Evidence	<code>// Handle query parameters</code>
Other Info	The following pattern was used: <code>\bQUERY\b</code> and was detected 61 times, the first in likely comment: <code>"// Handle query parameters", see evidence field for the suspicious comment/snippet.</code>
URL	http://localhost:3000/_next/static/chunks/_6592d88f._.js
Node Name	<code>http://localhost:3000/_next/static/chunks/_6592d88f._.js</code>
Method	GET
Parameter	
Attack	
Evidence	<code>// TODO: Update OpenAPI sch</code>
Other Info	The following pattern was used: <code>\bTODO\b</code> and was detected in likely comment: <code>"// TODO: Update OpenAPI schema for registration endpoint — until then,", see evidence field for the suspicious comment/snippet.</code>
URL	http://localhost:3000/_next/static/chunks/_6592d88f._.js
Node Name	<code>http://localhost:3000/_next/static/chunks/_6592d88f._.js</code>
Method	GET
Parameter	
Attack	
Evidence	<code>; * logger.info('User logged in', { userI</code>
Other Info	The following pattern was used: <code>\bUSER\b</code> and was detected 29 times, the first in likely comment: <code>"/**</code> <code>* Centralized logging utility with environment-aware behavior</code> <code>*</code> <code>* SECURITY: In production, logs generic messages only to ", see evidence field for the suspicious comment/snippet.</code>
URL	http://localhost:3000/_next/static/chunks/_6592d88f._.js
Node Name	<code>http://localhost:3000/_next/static/chunks/_6592d88f._.js</code>

Method	GET
Parameter	
Attack	
Evidence	content-type header from a fetch Response, t
Other Info	The following pattern was used: \bFROM\b and was detected 76 times, the first in likely comment: "/** * Extract the content-type header from a fetch Response, tolerating test * mocks that pass a plain-object `headers` ma", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/_6592d88f._.js
Node Name	http://localhost:3000/_next/static/chunks/_6592d88f._.js
Method	GET
Parameter	
Attack	
Evidence	d / session restore where the token only live
Other Info	The following pattern was used: \bWHERE\b and was detected 2 times, the first in likely comment: "/** * Resolve the auth token for direct `fetch()` downloads. * * The typed client keeps an in-memory copy, but that can be em", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/_6592d88f._.js
Node Name	http://localhost:3000/_next/static/chunks/_6592d88f._.js
Method	GET
Parameter	
Attack	
Evidence	er CRUD operations (admin) * - User statisti
Other Info	The following pattern was used: \bADMIN\b and was detected 46 times, the first in likely comment: "/** * Users API Module (OpenAPI-typed) * * Handles user-related operations including: * - Profile management * - Student in", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/_6592d88f._.js
Node Name	http://localhost:3000/_next/static/chunks/_6592d88f._.js
Method	GET

Parameter	
Attack	
Evidence	g primitive: * Select, DropdownMenu, Dial
Other Info	The following pattern was used: \bSELECT\b and was detected in likely comment: "/* * Client-side plumbing for the per-request CSP nonce. Issue #1273. * * With production `style-src` nonce-gated (no 'unsaf', see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/_6592d88f._.js
Node Name	http://localhost:3000/_next/static/chunks/_6592d88f._.js
Method	GET
Parameter	
Attack	
Evidence	hose allocation was later revoked or suspende
Other Info	The following pattern was used: \bLATER\b and was detected in likely comment: "/* * 取得造冊中已撤銷/停發的學生清單 * Lists students still embedded in a locked roster whose allocation was later revoked or suspen", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/components_enhanced-student-portal_tsx_ac266d54._.js
Node Name	http://localhost:3000/_next/static/chunks/components_enhanced-student-portal_tsx_ac266d54._.js
Method	GET
Parameter	
Attack	
Evidence	// Debug authentication stat
Other Info	The following pattern was used: \bDEBUG\b and was detected 5 times, the first in likely comment: "// Debug authentication status", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/components_enhanced-student-portal_tsx_ac266d54._.js
Node Name	http://localhost:3000/_next/static/chunks/components_enhanced-student-portal_tsx_ac266d54._.js
Method	GET
Parameter	
Attack	
Evidence	editing application from the applications li
Other Info	The following pattern was used: \bFROM\b and was detected 3 times, the first in likely comment: "// Get the editing application from the applications list", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/components_user-permission-management_tsx_eb418631._.js
Node Name	http://localhost:3000/_next/static/chunks/components_user-permission-management_tsx_eb418631._.js

Method	GET
Parameter	
Attack	
Evidence	// User management states
Other Info	The following pattern was used: \bUSER\b and was detected 3 times, the first in likely comment: "// User management states", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/components_user-permission-management_tsx_eb418631._.js
Node Name	http://localhost:3000/_next/static/chunks/components_user-permission-management_tsx_eb418631._.js
Method	GET
Parameter	
Attack	
Evidence	ons for non-college/admin roles
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "// Remove all permissions for non-college/admin roles", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a._.js
Node Name	http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a._.js
Method	GET
Parameter	
Attack	
Evidence	find the pathname, query and hash and return
Other Info	The following pattern was used: \bQUERY\b and was detected in likely comment: "/* * Given a path this function will find the pathname, query and hash and return * them. This is useful to parse full paths ", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a._.js
Node Name	http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a._.js
Method	GET
Parameter	
Attack	
Evidence	// TODO: We should hoist th
Other Info	The following pattern was used: \bTODO\b and was detected 10 times, the first in likely comment: "// TODO: We should hoist the search params out of the FlightRouterState", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a._.js
Node Name	http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a._.js
Method	GET
Parameter	
Attack	

Evidence	// from user code generated by W
Other Info	The following pattern was used: \bUSER\b and was detected 4 times, the first in likely comment: "// from user code generated by Webpack. For more information see", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a_.js
Node Name	http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a_.js
Method	GET
Parameter	
Attack	
Evidence	// where rust does not have
Other Info	The following pattern was used: \bWHERE\b and was detected 6 times, the first in likely comment: "// where rust does not have easy way to represnt js's 53-bit float number type for the matching", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a_.js
Node Name	http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a_.js
Method	GET
Parameter	
Attack	
Evidence	ntime expose Object from vm, being that kind
Other Info	The following pattern was used: \bFROM\b and was detected 19 times, the first in likely comment: <code>"/**</code> <code>* this used to be previously:</code> <code>*</code> <code>* `return prototype === null    prototype === Object.prototype`</code> <code>*</code> <code>* but Edge ", see evidence field for the suspicious comment/snippet.</code>
URL	http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a_.js
Node Name	http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a_.js
Method	GET
Parameter	
Attack	
Evidence	to report this as a bug in Next.js.
Other Info	The following pattern was used: \bBUG\b and was detected in likely comment: "// user to report this as a bug in Next.js.", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188_.js
Node Name	http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188_.js
Method	GET
Parameter	

Attack	
Evidence	if that's what the user passed in, hence th
Other Info	The following pattern was used: <code>\bUSER\b</code> and was detected 3 times, the first in likely comment: <code>"/**</code> * Note that we intentionally do not use <code>`url.searchParams.set`</code> here: * * <code>const url = new URL("https://example.com/s",</code> see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js
Node Name	http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js
Method	GET
Parameter	
Attack	
Evidence	// (where these errors can oc
Other Info	The following pattern was used: <code>\bWHERE\b</code> and was detected 14 times, the first in likely comment: <code>"/ (where these errors can occur), we will get the correct pathname."</code> , see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js
Node Name	http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js
Method	GET
Parameter	
Attack	
Evidence	// TODO: Dispatch error eve
Other Info	The following pattern was used: <code>\bTODO\b</code> and was detected 62 times, the first in likely comment: <code>"/ TODO: Dispatch error event"</code> , see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js
Node Name	http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js
Method	GET
Parameter	
Attack	
Evidence	// <code>`__nextppronly`</code> query is present. This is
Other Info	The following pattern was used: <code>\bQUERY\b</code> and was detected 5 times, the first in likely comment: <code>"/ `__nextppronly` query is present. This is only enabled when the"</code> , see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js
Node Name	http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js
Method	GET
Parameter	
Attack	

Evidence	gURL=set-attributes-from-props.js.map
Other Info	The following pattern was used: \bFROM\b and was detected 76 times, the first in likely comment: "//# sourceMappingURL=set-attributes-from-props.js.map", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js
Node Name	http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js
Method	GET
Parameter	
Attack	
Evidence	it didn't, due to a bug or race condition,
Other Info	The following pattern was used: \bBUG\b and was detected 2 times, the first in likely comment: "// If for some reasons it didn't, due to a bug or race condition, then on", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js
Node Name	http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js
Method	GET
Parameter	
Attack	
Evidence	ra prefetch request later, since we already h
Other Info	The following pattern was used: \bLATER\b and was detected 3 times, the first in likely comment: "// prefetch cache so that we can skip an extra prefetch request later, since we already have the data.", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/node_modules_next_dist_compiled_5150ccfd._.js
Node Name	http://localhost:3000/_next/static/chunks/node_modules_next_dist_compiled_5150ccfd._.js
Method	GET
Parameter	
Attack	
Evidence	// TODO: rename these field
Other Info	The following pattern was used: \bTODO\b and was detected 3 times, the first in likely comment: "// TODO: rename these fields to something more meaningful.", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/node_modules_next_dist_compiled_5150ccfd._.js
Node Name	http://localhost:3000/_next/static/chunks/node_modules_next_dist_compiled_5150ccfd._.js
Method	GET
Parameter	
Attack	
Evidence	ogic is copy-pasted from similar logic in th
Other Info	The following pattern was used: \bFROM\b and was detected 4 times, the first in likely comment: "// This logic is copy-pasted from similar logic in the DevTools backend.", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js

Node Name	http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js
Method	GET
Parameter	
Attack	
Evidence	a Refresh Boundary later.
Other Info	The following pattern was used: \bLATER\b and was detected in likely comment: "// still a Refresh Boundary later.", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js
Node Name	http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js
Method	GET
Parameter	
Attack	
Evidence	// TODO(luke.sandberg): we
Other Info	The following pattern was used: \bTODO\b and was detected 12 times, the first in likely comment: "// TODO(luke.sandberg): we could support raw values here, but would need a discriminator beyond 'not a function'", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js
Node Name	http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js
Method	GET
Parameter	
Attack	
Evidence	ative to the origin where a chunk can be fetc
Other Info	The following pattern was used: \bWHERE\b and was detected 2 times, the first in likely comment: <code>"/**</code> * Returns the URL relative to the origin where a chunk can be fetched from. */", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js
Node Name	http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js
Method	GET
Parameter	
Attack	
Evidence	consistent from the user's perspective.
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "// the HTML somewhat consistent from the user's perspective.", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js
Node Name	http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js
Method	GET

Parameter	
Attack	
Evidence	ead of accessing it from the module object t
Other Info	The following pattern was used: \bFROM\b and was detected 20 times, the first in likely comment: "// We need to store this here instead of accessing it from the module object to:", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js
Node Name	http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js
Method	GET
Parameter	
Attack	
Evidence	onally followed by ?query or #fragment. */
Other Info	The following pattern was used: \bQUERY\b and was detected 3 times, the first in likely comment: "/* * Checks if a given path/URL ends with .js, optionally followed by ?query or #fragment. */", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js
Node Name	http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js
Method	GET
Parameter	
Attack	
Evidence	stylesheet: https://bugs.webkit.org/show_bug
Other Info	The following pattern was used: \bBUGS\b and was detected in likely comment: "// pointing to the same URL as the stylesheet: https://bugs.webkit.org/show_bug.cgi?id=187726", see evidence field for the suspicious comment/snippet.
Instances	36
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.
URL	http://localhost:3000
Node Name	http://localhost:3000
Method	GET
Parameter	

Attack	
Evidence	<script src="/_next/static/chunks/node_modules_next_dist_compiled_react-dom_1e674e59._.js" async=""></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:3000/
Node Name	http://localhost:3000/
Method	GET
Parameter	
Attack	
Evidence	<script src="/_next/static/chunks/node_modules_next_dist_compiled_react-dom_1e674e59._.js" async=""></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:3000/robots.txt
Node Name	http://localhost:3000/robots.txt
Method	GET
Parameter	
Attack	
Evidence	<script src="/_next/static/chunks/node_modules_next_dist_compiled_react-dom_1e674e59._.js" async=""></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	<script src="/_next/static/chunks/node_modules_next_dist_compiled_react-dom_1e674e59._.js" async=""></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	4
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informational	Non-Storable Content
Description	The response contents are not storable by caching components such as proxy servers. If the response does not contain sensitive, personal or user-specific information, it may benefit from being stored and cached, to improve performance.

URL	http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._js
Node Name	http://localhost:3000/_next/static/chunks/[turbopack]_browser_dev_hmr-client_hmr-client_ts_57d40746._js
Method	GET
Parameter	
Attack	
Evidence	no-store
Other Info	
URL	http://localhost:3000/_next/static/chunks/_a0ff3932._js
Node Name	http://localhost:3000/_next/static/chunks/_a0ff3932._js
Method	GET
Parameter	
Attack	
Evidence	no-store
Other Info	
URL	http://localhost:3000/_next/static/chunks/_e084681a._css
Node Name	http://localhost:3000/_next/static/chunks/_e084681a._css
Method	GET
Parameter	
Attack	
Evidence	no-store
Other Info	
URL	http://localhost:3000/robots.txt
Node Name	http://localhost:3000/robots.txt
Method	GET
Parameter	
Attack	
Evidence	no-store
Other Info	
URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	no-store
Other Info	

Instances	Systemic
Solution	The content may be marked as storable by ensuring that the following conditions are satisfied: The request method must be understood by the cache and defined as being cacheable ("GET", "HEAD", and "POST" are currently defined as cacheable) The response status code must be understood by the cache (one of the 1XX, 2XX, 3XX, 4XX, or 5XX response classes are generally understood) The "no-store" cache directive must not appear in the request or response header fields For caching by "shared" caches such as "proxy" caches, the "private" response directive must not appear in the response For caching by "shared" caches such as "proxy" caches, the "Authorization" header field must not appear in the request, unless the response explicitly allows it (using one of the "must-revalidate", "public", or "s-maxage" Cache-Control response directives) In addition to the conditions above, at least one of the following conditions must also be satisfied by the response: It must contain an "Expires" header field It must contain a "max-age" response directive For "shared" caches such as "proxy" caches, it must contain a "s-maxage" response directive It must contain a "Cache Control Extension" that allows it to be cached It must have a status code that is defined as cacheable by default (200, 203, 204, 206, 300, 301, 404, 405, 410, 414, 501).
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html
CWE Id	524
WASC Id	13
Plugin Id	10049

Informational	Sec-Fetch-Dest Header is Missing
Description	Specifies how and where the data would be used. For instance, if the value is audio, then the requested resource must be audio data and not any other type of resource.
URL	http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._.js
Node Name	http://localhost:3000/_next/static/chunks/[turbopack]_browser_dev_hmr-client_hmr-client_ts_57d40746._.js
Method	GET
Parameter	Sec-Fetch-Dest
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/icon.svg
Node Name	http://localhost:3000/icon.svg
Method	GET

Parameter	Sec-Fetch-Dest
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/nycu-favicon.svg
Node Name	http://localhost:3000/nycu-favicon.svg
Method	GET
Parameter	Sec-Fetch-Dest
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-Dest header is included in request headers.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Dest
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	Sec-Fetch-Mode Header is Missing
Description	Allows to differentiate between requests for navigating between HTML pages and requests for loading resources like images, audio etc.
URL	http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._.js
Node Name	http://localhost:3000/_next/static/chunks/[turbopack]_browser_dev_hmr-client_hmr-client_ts_57d40746._.js
Method	GET
Parameter	Sec-Fetch-Mode
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/icon.svg
Node Name	http://localhost:3000/icon.svg
Method	GET
Parameter	Sec-Fetch-Mode
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/nycu-favicon.svg
Node Name	http://localhost:3000/nycu-favicon.svg

Method	GET
Parameter	Sec-Fetch-Mode
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-Mode header is included in request headers.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Mode
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	Sec-Fetch-Site Header is Missing
Description	Specifies the relationship between request initiator's origin and target's origin.
URL	http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._js
Node Name	http://localhost:3000/_next/static/chunks/[turbopack]_browser_dev_hmr-client_hmr-client_ts_57d40746._js
Method	GET
Parameter	Sec-Fetch-Site
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/icon.svg
Node Name	http://localhost:3000/icon.svg
Method	GET
Parameter	Sec-Fetch-Site
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/nycu-favicon.svg
Node Name	http://localhost:3000/nycu-favicon.svg
Method	GET
Parameter	Sec-Fetch-Site
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-Site header is included in request headers.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Site

CWE Id	352
WASC Id	9
Plugin Id	90005
Informational	Sec-Fetch-User Header is Missing
Description	Specifies if a navigation request was initiated by a user.
URL	http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._.js
Node Name	http://localhost:3000/_next/static/chunks/[turbopack]_browser_dev_hmr-client_hmr-client_ts_57d40746._.js
Method	GET
Parameter	Sec-Fetch-User
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/icon.svg
Node Name	http://localhost:3000/icon.svg
Method	GET
Parameter	Sec-Fetch-User
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/nycu-favicon.svg
Node Name	http://localhost:3000/nycu-favicon.svg
Method	GET
Parameter	Sec-Fetch-User
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-User header is included in user initiated requests.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-User
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	Storable but Non-Cacheable Content
Description	The response contents are storable by caching components such as proxy servers, but will not be retrieved directly from the cache, without validating the request upstream, in response to similar requests from other users.
URL	http://localhost:3000/icon.svg

Node Name	http://localhost:3000/icon.svg
Method	GET
Parameter	
Attack	
Evidence	max-age=0
Other Info	
URL	http://localhost:3000/nycu-favicon.svg
Node Name	http://localhost:3000/nycu-favicon.svg
Method	GET
Parameter	
Attack	
Evidence	max-age=0
Other Info	
Instances	2
Solution	
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html
CWE Id	524
WASC Id	13
Plugin Id	10049

Sequence Details

With the associated active scan results.